TECHNICAL DETAIL

Title	Attendance Bypass via Client-Side Geolocation Spoofing & Information Disclosure
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://pegawai.my.id/presences/create
Severity	Medium
CVSS Score	5.3 CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Proof of Concepts	Please see Steps to Reproduce section

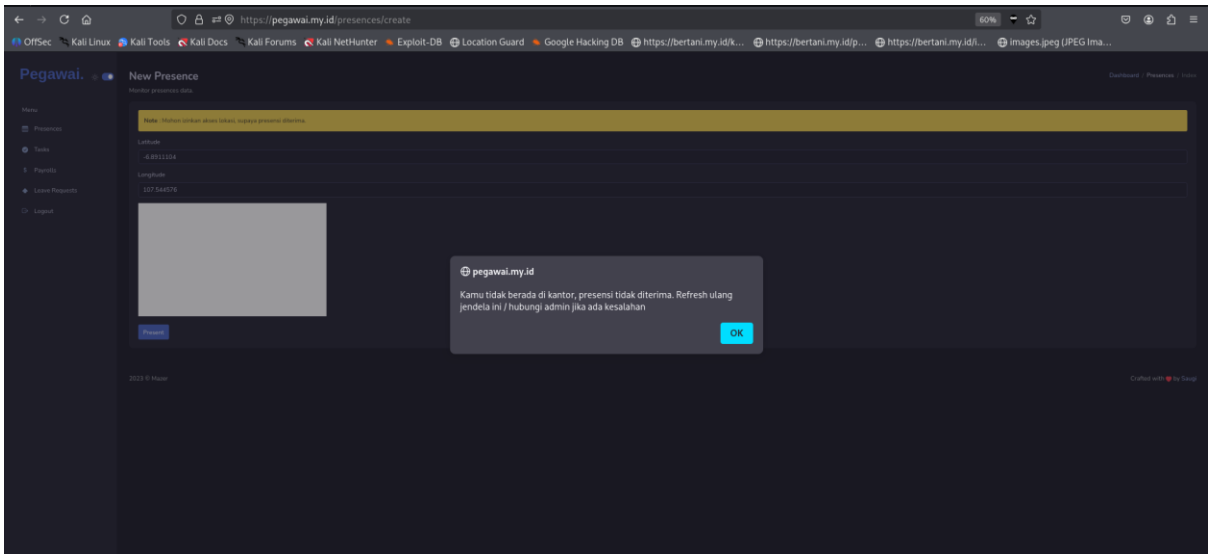
SUMMARY

Ditemukan kerentanan logika bisnis (*Business Logic Flaw*) pada fitur absensi di situs web pegawai.my.id. Situs web ini melakukan validasi lokasi hanya di sisi klien (*Client-Side*) dan mengekspos koordinat lokasi kantor secara terang-terangan (hardcoded) di dalam *Source Code* JavaScript.

Hal ini memungkinkan pengguna untuk memanipulasi lokasi mereka menggunakan *browser extension* atau alat *GPS Spoofing* agar sesuai dengan koordinat kantor. Akibatnya, karyawan dapat melakukan absensi (Check-In) melalui browser dari lokasi mana pun tanpa harus benar-benar berada di kantor, yang mengarah pada kecurangan absensi.

STEPS TO REPRODUCE

1. Login ke Akun anda sebagai user di URL https://pegawai.my.id/login
2. Siapkan extension geolocation
3. buka URL https://pegawai.my.id/presences/create.

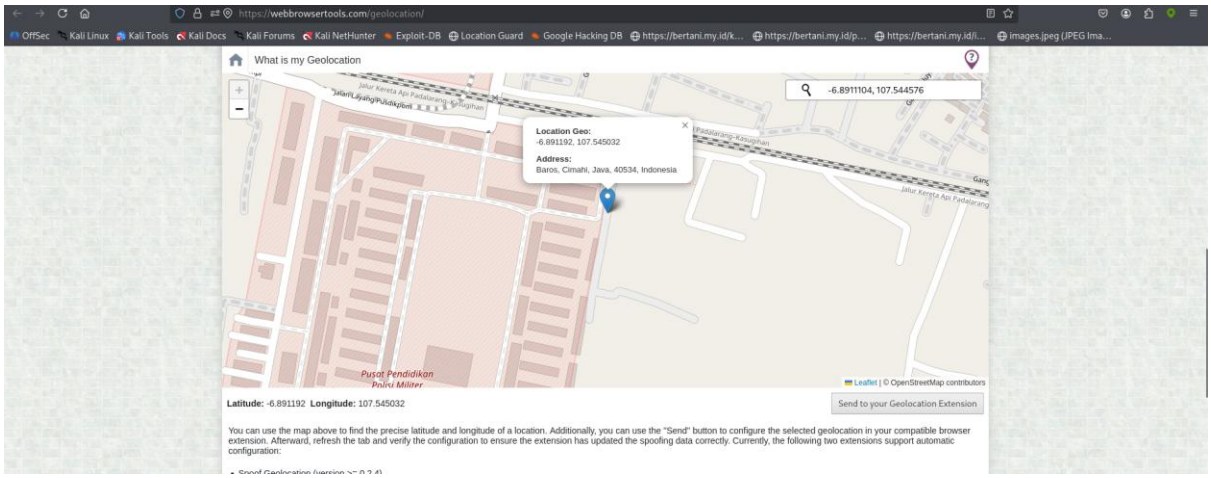


4. Buka page source nya maka akan terlihat Lokasi kantor yang seharusnya

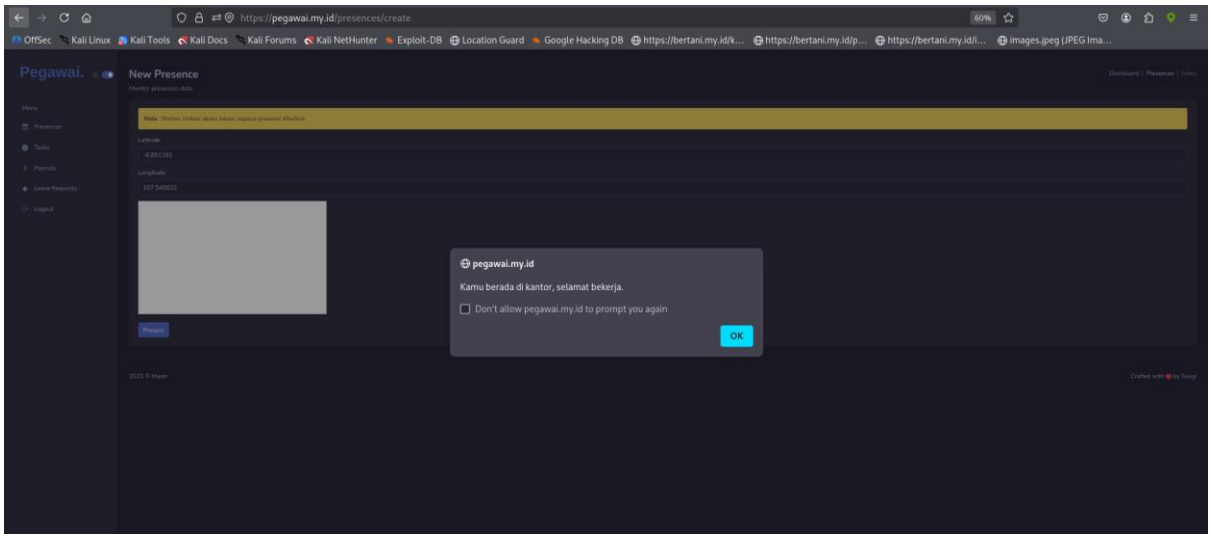
```
<script>
    const iframe = document.querySelector('iframe');
    // const officeLat = -6.200000; // Latitude for Jakarta
    // const officeLon = 106.816666; // Longitude for Jakarta
    // const threshold = 0.01; // Threshold for distance comparison

    // Latitude for Office.
    const officeLat = -6.8911104;
    const officeLon = 107.544576;
    const threshold = 0.01;
```

5. Ganti Lokasi menggunakan geolocation masukan koordinat yang kita lihat di pagesource



6. Lalu aktifkan extensionnya dan Lokasi berhasil di manipulasi



EXPECTED RESULT

1. Koordinat lokasi kantor idealnya tidak diekspos secara *hardcoded* di sisi klien (browser), atau setidaknya situs web tidak boleh bergantung sepenuhnya pada validasi sisi klien.
2. Situs web seharusnya menerapkan validasi sisi server (*Server-Side Validation*) tambahan, seperti pengecekan Alamat IP (IP Whitelisting). Absensi hanya boleh diterima jika request berasal dari IP Public Wi-Fi kantor.
3. Situs web harus mendeteksi penggunaan *mock location* atau inkonsistensi data lokasi jika memungkinkan

ACTUAL RESULT

1. Koordinat kantor terlihat jelas di *Source Code* web (view-source).
2. Situs web mempercayai input Geolocation API dari browser tanpa validasi integritas.
3. Pengguna berhasil melakukan absensi palsu dari lokasi berbeda.

IMPACT

1. Attendance Fraud: Karyawan dapat memalsukan kehadiran mereka (bolos kerja tapi tetap absen).
2. Financial Loss: Perusahaan membayar gaji untuk jam kerja yang tidak valid.
3. Data Integrity: Rekaman data kehadiran menjadi tidak akurat dan tidak dapat dipercaya.

RECOMMENDATION

1. IP Address Whitelisting (Recommended): Tambahkan validasi di sisi server untuk mengecek Alamat IP pengirim. Izinkan absensi HANYA jika pengguna terhubung ke jaringan Wi-Fi kantor (IP Statis Kantor). Ini adalah cara paling efektif mencegah *GPS Spoofing* pada aplikasi web.
2. Remove Hardcoded Coordinates: Hindari menampilkan logika validasi sensitif di sisi klien. Lakukan perhitungan jarak (Haversine Formula) di sisi server (Backend), bukan di JavaScript browser.
3. Audit Logs: Pantau pola absensi yang mencurigakan (misalnya, perpindahan lokasi yang mustahil dalam waktu singkat).

REFERENCES

1. CWE-602: Client-Side Enforcement of Server-Side Security: https://cwe.mitre.org/data/definitions/602.html
2. OWASP - Business Logic Vulnerability: https://owasp.org/www-community/vulnerabilities/Business_logic_vulnerability